Zero Trust Architecture

VMware Cloud Foundation 9.1

August 2026

vmware by Broadcom

Table of Contents

Disclaimer 3

Third-Party Identifiers and Mappings 4

Executive Summary 5

Introduction 6

Product Definitions 7

Assessment Method and Secure Controls Framework 8

Identity and Access 9

Device Trust and Posture 10

Network and Environment Isolation 11

Application and Workload Protection 12

Data Protection 13

Visibility and Analytics 14

Automation and Orchestration 15

Mapping to the NIST SP 800-207 Tenets 16

Mapping to the NIST SP 800-207 Deployment Approaches 17

Designing a Zero Trust Architecture on VCF 18

Mapping to the CISA Zero Trust Maturity Model 19

Mitigating Zero Trust Architecture Threats from SP 800-207 20

Capability Contribution Matrices 21

VMware Cloud Foundation 21

VMware vDefend 23

Conclusion 25

Appendix: Enterprise Components That Complete Each Pillar 26

Additional Resources 27

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided "AS IS." Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Third-Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers from the Secure Controls Framework, version 2026.1.1, have been reproduced under the Creative Commons Attribution-NoDerivatives 4.0 International Public License. The Secure Controls Framework Council, LLC, is the licensor. No modifications have been made to the control identifier numbers.

Executive Summary

VMware Cloud Foundation (VCF), together with VMware vDefend, supplies infrastructure-layer mechanisms that can contribute to a Zero Trust architecture. Relevant reference points include National Institute of Standards and Technology (NIST) Special Publication (SP) 800-207, the U.S. Department of Defense (DoD) Zero Trust Reference Architecture and Capability Execution Roadmap, and the Cybersecurity and Infrastructure Security Agency (CISA) Zero Trust Maturity Model.

The strongest product contributions are in the Network and Environment pillar, where VMware vDefend Distributed Firewall can enforce identity- and application-context-aware micro-segmentation for supported virtual workloads. In the User pillar, VCF SSO federation and role-based access control (RBAC) provide mechanisms for authentication and least-privilege authorization. In the Device pillar, Secure Boot, Trusted Platform Module (TPM) attestation, inventory, configuration monitoring, and lifecycle management provide evidence about VMware ESX host state. In the Data pillar, storage and virtual machine encryption and customer-controlled key options provide data-protection mechanisms when they are configured for the deployment.

VCF and vDefend supply infrastructure enforcement points and telemetry that integrate with enterprise identity, security information and event management (SIEM), analytics, privileged-access, endpoint-security, and data-governance systems. The published NIST SP 800-207 Companion Guide for VCF 9.1 provides the NIST contribution ratings. The DoD and CISA mappings use capability-level comparisons rather than published Secure Controls Framework (SCF) crosswalks, product certifications, or assessments of an organization's compliance or maturity.

Introduction

Zero Trust is a security model built on the principle that an actor, system, or network segment is not trusted solely because of its location. Access decisions evaluate the subject, device, resource, and available context against policy, and authorization is scoped to a session or request as the architecture requires. Communication protection is based on resource sensitivity, risk, and policy rather than an assumption that an internal network is trusted.

Several frameworks define the current state of Zero Trust architecture. NIST Special Publication 800-207, published in August 2020, establishes the foundational principles through seven tenets, a logical component model (Policy Engine, Policy Administrator, Policy Enforcement Point), and three deployment approaches: enhanced identity governance, micro-segmentation, and network infrastructure and software-defined perimeters. Executive Order 14028, *Improving the Nation's Cybersecurity* (May 2021), directed federal agencies to adopt Zero Trust architectures. Office of Management and Budget (OMB) Memorandum M-22-09 (January 2022) translated that direction into specific requirements organized around five pillars: identity, devices, networks, applications and workloads, and data. The U.S. Department of Defense Zero Trust Reference Architecture (version 2.0) and the DoD Zero Trust Strategy, published in 2022, build on the NIST foundation and organize Zero Trust into seven operational pillars: User, Device, Network and Environment, Application and Workload, Data, Visibility and Analytics, and Automation and Orchestration. The companion DoD Zero Trust Capability Execution Roadmap decomposes those pillars into 45 capabilities and 152 activities (91 target, 61 advanced) that constitute a measurable implementation. The CISA Zero Trust Maturity Model (version 2.0, April 2023) provides four maturity levels (Traditional, Initial, Advanced, and Optimal) across five pillars and three cross-cutting capabilities.

Product Definitions

The scope includes core VCF and the separately licensed VMware vDefend advanced service. Their licensing, deployment models, and contributions differ.

- **VMware Cloud Foundation (core)** is the full-stack platform spanning compute, storage, networking, and management. It supplies mechanisms for identity integration, host-state evidence, workload isolation, encryption, software-defined networking, logging, and lifecycle management.
- **VMware vDefend** is a separately licensed advanced service that extends NSX, VCF's networking layer, with network security enforcement and threat detection. Its management plane is the Security Services Platform (SSP).

Offering	Licensing	Key components	Primary Zero Trust contribution
VMware Cloud Foundation	Base platform	VMware Certificate Authority (VMCA), VCF SSO and role-based access control, VMware ESX with Secure Boot and TPM attestation, vSAN and VM encryption, NSX software-defined networking, VCF Operations, VCF Log Management, vSphere Lifecycle Manager	User identity and least privilege, Device host trust, the Network foundation, Data encryption, Visibility, and configuration and patch Automation
VMware vDefend	Separately licensed advanced service	Distributed Firewall, VMware vDefend Gateway Firewall, Identity Firewall, Application ID, Distributed IDS/IPS (intrusion detection and prevention), Network Detection and Response, Advanced Threat Prevention, Security Intelligence (managed through the Security Services Platform)	Network and Environment enforcement through micro-segmentation, network Resource Authorization, and the network layers of Visibility and Analytics

NSX supplies routing and connectivity. VMware vDefend supplies firewalling, segmentation enforcement, and threat detection as a separately licensed advanced service.

Assessment Method and Secure Controls Framework

The Broadcom NIST SP 800-207 Companion Guide for VCF 9.1, version 910-20260623-01, maps each NIST tenet to SCF identifiers and rates each assessed product as *Meets*, *Contributes*, *Not Applicable*, *Not Supported*, or *Not Assessed*. The mapping uses *Direct* for *Meets* and *Supporting* for *Contributes*. The DoD comparison is capability-level rather than an SCF crosswalk or activity-level compliance assessment. The CISA comparison identifies technical contributions and external dependencies without assigning an organization-wide maturity stage. Product availability and behavior can vary by VCF version, deployment model, entitlement, and configuration. Organizations should validate each mechanism against the release-specific documentation for their environment.

Identity and Access

NIST Tenets 3 and 6. DoD User pillar.

The core of Zero Trust is the shift from network-location-based trust to access decisions based on identity, device state, resource context, and policy. NIST SP 800-207 calls for per-session access, least privilege, and dynamic authentication and authorization before access is allowed. The DoD User pillar adds named capabilities for Multi-Factor Authentication and continuous authentication. Its capability set covers User Inventory; Conditional User Access; Multi-Factor Authentication; Privileged Access Management; Identity Federation and Credentialing; Behavioral, Contextual ID, and Biometrics; Least Privileged Access; Continuous Authentication; and an Integrated Identity, Credential, and Access Management (ICAM) Platform.

VCF SSO is the centralized authentication service for supported VCF components. It can federate interactive authentication with an external identity provider through supported Security Assertion Markup Language (SAML) or OpenID Connect (OIDC) configurations. Depending on the component and configuration, just-in-time (JIT) provisioning, System for Cross-domain Identity Management (SCIM), or Active Directory/Lightweight Directory Access Protocol (AD/LDAP) integration supplies user and group records. Organizations can apply multifactor authentication, conditional-access, device-posture, and geographic policies to supported federated sign-ins. Local, emergency, service-account, and API authentication paths require separate controls. Broadcom documents the distinction between modern identity-provider authentication and directory-based provisioning in KB 386870.

VCF provides centralized and component-level role-based access control as the basis for least-privilege design. Permissions can be scoped by function and inventory location, which allows administrators to limit a role to specified activities on specified objects. VCF-level roles support centralized assignment of privilege bundles across VMware vCenter, NSX, VCF Operations, and VCF Automation, while individual components retain their own authorization models and integration paths. Organizations should validate role mapping, inheritance, federation behavior, and emergency-access design for each component. VCF can participate in just-in-time or time-limited access workflows when integrated with enterprise identity and privileged access management (PAM) tooling; a full PAM program depends on that external tooling and supporting organizational processes.

For supported automation workflows and APIs, VCF SSO supports OAuth 2.0 and API clients or tokens whose permissions are governed by assigned roles. Organizations can use scoped, revocable credentials instead of embedding user passwords in scripts. A stolen token retains the permissions and lifetime assigned to it, so narrow scopes, short lifetimes where supported, rotation, and monitoring reduce exposure.

At the credential and key layer, vSphere includes the VMware Certificate Authority (VMCA), which issues and manages certificates for supported vSphere components and solution users. Other VCF components have their own documented certificate-management and trust-integration paths. These certificate mechanisms and identity federation can integrate with an enterprise ICAM architecture, but VCF does not provide enterprise identity governance, user credential issuance, or access recertification. Where local or directory-backed authentication is used, the applicable component controls password policy. For supported federated sign-ins, the external identity provider applies its password, multifactor-authentication, conditional-access, and session-risk policies.

vDefend contributes to this pillar at the network layer. The Identity Firewall can apply firewall rules using Active Directory user and group membership, including for supported Virtual Desktop Infrastructure sessions. Organizations whose authoritative identity source is elsewhere should account for that dependency when planning identity-aware network policy. The Security Services Platform (SSP), which is the vDefend management plane, provides built-in roles with differentiated permissions so administrators can separate management responsibilities.

Device Trust and Posture

NIST Tenet 5. DoD Device pillar.

The DoD Zero Trust model expects device identity and security posture to inform access decisions. The capability set here includes Device Inventory, Device Detection and Compliance, Device Authorization with Real-Time Inspection, Asset, Vulnerability and Patch Management, and Endpoint and Extended Detection and Response. Within the scope of VCF infrastructure, the ESX hypervisor host is a foundational managed device. VCF exposes inventory, boot-attestation status, configuration posture, and lifecycle state that an organization can evaluate as part of its device-trust policy.

Secure Boot validates signed components in the ESX boot chain. TPM 2.0 Measured Boot records measurements of boot components in platform configuration registers, and a verifier can use the resulting attestation report to evaluate the reported boot state. These mechanisms provide hardware-rooted evidence about boot integrity; they do not establish the ongoing trustworthiness of every process or configuration on the host. VCF Operations can alert on reported attestation failures, and the VCF Security Configuration Guide provides TPM configuration guidance. The Broadcom TPM attestation API documentation describes the measurements, event log, and reliability indicator available to a verifier.

vCenter updates its inventory as managed objects are added, changed, or removed. VCF Operations maintains configuration-item records for monitored virtual infrastructure and provides integration points for external configuration management database (CMDB) platforms. Supported infrastructure connections use certificate-based authentication according to each component's trust model. The applicable certificate authority, mutual-authentication behavior, and validation scope vary by component and connection.

VCF Operations and vSphere Lifecycle Manager coordinate supported lifecycle workflows, including pre-update health and compatibility checks. Desired images and configuration baselines support drift detection and reporting for the components they cover. Documented image-transfer workflows use checksum validation to detect unintended changes in transferred content. Management-appliance change detection and supported third-party endpoint or antimalware integrations can contribute evidence to enterprise vulnerability, integrity-monitoring, and endpoint-security programs. These mechanisms do not replace enterprise vulnerability discovery, prioritization, exception handling, or endpoint detection and response.

For endpoint detection and response (EDR) and extended detection and response (XDR), VCF supplies infrastructure telemetry and host-integrity information that supported external platforms can consume. VCF Log Management provides log analysis, event correlation, and forwarding for configured sources. vDefend extends detection to the network layer: its Network Detection and Response (NDR) capability classifies suspicious traffic, associates detections with specific MITRE ATT&CK techniques and tactics, and correlates related events into campaigns for triage. Unified endpoint management and mobile device management, which apply to user endpoints rather than data center infrastructure, are outside the scope of these products.

Network and Environment Isolation

NIST Tenets 2 and 4. DoD Network and Environment pillar.

NIST SP 800-207 presents micro-segmentation as one of three deployment approaches rather than as a universal requirement for every Zero Trust architecture. The DoD Roadmap makes Micro Segmentation a named Network and Environment capability and also identifies Data Flow Mapping, Software Defined Networking, and Macro Segmentation. The combined VCF and vDefend mechanisms contribute directly to each of those four DoD capabilities within the virtual infrastructure they manage.

NSX provides the software-defined networking foundation that decouples logical workload connectivity from much of the physical topology. Administrators manage overlays, logical segments, and routing through NSX Manager and its API. Supported NSX infrastructure connections use mutual Transport Layer Security (TLS) authentication. At the macro level, administrators can use VLANs, vSphere Distributed Switches, routing, and access controls to separate traffic by function and restrict management-network reachability to approved administrative paths.

VMware vDefend provides micro-segmentation through a distributed firewall in the ESX hypervisor. For supported and protected virtual workloads, policy is enforced at the virtual network interface below the guest operating system without an in-guest firewall agent. This separation means that a guest administrator does not directly manage the distributed firewall policy, which reduces the ability of a compromised guest to alter that enforcement. The control still depends on the integrity and availability of the host, management plane, policy administration, and product configuration. Policy is enforced locally on participating hosts, so east-west traffic can be evaluated without forwarding it through a central firewall appliance. Administrators can configure Layer 2 through Layer 7 rules, including application-aware rules, and can implement a default-deny model through staged policy deployment. NIST SP 800-207 section 5.1 addresses subversion of the policy engine and policy administrator; distributed enforcement at the workload interface does not by itself mitigate compromise of those decision and administration components.

Distributed firewall policy groups can determine membership from VM attributes, tags, and workload characteristics rather than relying only on network addresses. This model allows applicable policy to remain associated with a supported workload when it migrates between participating hosts. The Identity Firewall can base rules on Active Directory group membership, and Application ID can distinguish supported applications that share a port. Administrators can use that context to restrict services that are not permitted by policy. Within this scope, vDefend acts as a network-layer policy enforcement point that evaluates covered flows against centrally defined policy at the virtual interface.

vDefend supports staged segmentation so administrators can increase policy scope in reviewed steps. Infrastructure segmentation applies dedicated rules to shared services such as DNS, directory services, and time synchronization. Environment segmentation creates policy boundaries between zones such as development, staging, and production. Application segmentation defines permitted communication paths between application tiers using application identity and Layer 7 context. In multi-site deployments, a Global Manager can distribute supported vDefend policy to Local Managers. Available federation functions vary by release, so architects should validate the design against release-specific documentation.

VCF documents the ports and protocols required for supported component communication. Administrators can restrict access to those paths and use the supported TLS configurations for management traffic. Encryption in transit is available at several layers: vSAN data-in-transit encryption protects supported storage traffic between hosts, with hardware acceleration where available, and Encrypted vMotion protects configured live-migration traffic. Supported certificate-lifecycle workflows provide bulk operations, renewal, and replacement capabilities; organizations should validate prerequisites, service impact, and rollback procedures for the affected component and release.

VCF Operations for Networks and vDefend's Security Intelligence both support Data Flow Mapping, providing the network visibility needed to design segmentation boundaries.

Application and Workload Protection

NIST Tenet 1. DoD Application and Workload pillar.

The DoD model calls for workload isolation, integrity verification, and application-level access controls to reduce lateral-movement risk and restrict resource access. The capability set spans Application Inventory, Secure Software Development, Software Risk Management, Resource Authorization and Integration, and Continuous Monitoring and Ongoing Authorizations. VCF provides the isolation and resource-authorization mechanisms; the software development and supply-chain capabilities are organizational and toolchain responsibilities.

The ESX hypervisor mediates isolation between virtual machines, including separate guest address spaces and virtualized access to physical resources. This boundary does not replace guest operating system hardening, image-integrity controls, identity governance, backup security, or operational change control.

VCF components evaluate supported management requests against permissions within their respective authorization domains, and vDefend evaluates network flows covered by configured policy. VMware vSphere Kubernetes Service (VKS) deploys Kubernetes clusters whose control-plane and worker nodes run as virtual machines selected through VM classes. Hypervisor isolation applies between those node VMs, while container isolation within a node remains a Kubernetes and container-runtime responsibility. Namespace-level RBAC scopes Kubernetes API permissions, but cluster-wide roles and bindings can grant access across namespaces, and workload traffic isolation requires applicable network policy. The VKS documentation describes the VM-based cluster topology, and the Kubernetes RBAC documentation describes namespace and cluster scopes. vCenter inventories managed virtual machines, while the Security Services Platform inventories network-visible workloads within its configured scope.

Within the management plane, VCF Management Services (VCFMS) runs platform components as containerized services. Administrators can use dedicated placement, networking, access-control, and vSphere Zone designs to separate management services from tenant workloads. The resulting security boundary depends on the complete compute, network, identity, and policy configuration; a vSphere Zone assignment alone is not a guarantee of compromise containment.

Data Protection

NIST Tenet 2. DoD Data pillar.

The DoD Data pillar requires encryption at rest and in transit, data access monitoring, and key management, alongside data governance capabilities such as cataloging, labeling, and loss prevention. VCF provides the infrastructure-level data protection capabilities, along with the enforcement points and tagging metadata that data-governance programs direct; classification, labeling, and content-aware loss prevention operate at the organizational and application layer.

vSAN data-at-rest encryption protects stored blocks using keys from an external Key Management Server (KMS) or the vSphere Native Key Provider. If encrypted media is removed and the required keys remain unavailable, the stored ciphertext is designed to remain unreadable; the result depends on correct encryption and key-management configuration. An external KMS allows an organization to administer keys outside the platform that consumes them. VM encryption provides a separate virtual-machine-level control independent of the storage backend, and vSAN data-in-transit encryption supports configurable rekey intervals with per-host key generation. Certain components can be configured to use modules validated under the Federal Information Processing Standards (FIPS), subject to the validation certificate, version, operating environment, and required configuration. FIPS validation applies only to the documented module, version, operating environment, and configuration rather than to VCF as a whole. The vSphere CryptoManager object hierarchy exposes controls for supported key-provider, access, lifecycle, and availability operations. Broadcom publishes configuration and scoping details in the VCF encryption guidance.

For data access monitoring, VCF Log Management can collect supported infrastructure and management-plane audit events from configured sources. The resulting time-correlated audit trail records available details about administrative and platform actions on VCF-managed objects, including actor, action, time, and source where the event provides those fields. At the network layer, vDefend contributes to data monitoring and to limiting exfiltration: the distributed firewall restricts which workloads can communicate and over which protocols, narrowing the paths by which sensitive data could leave a segment, and integrates NSX tags with policy so that information-flow controls can reference data-classification metadata applied to workloads. Content-aware data loss prevention remains a dedicated data-layer capability that these network-layer controls complement.

Visibility and Analytics

NIST Tenet 7. DoD Visibility and Analytics pillar.

The DoD model treats visibility and analytics as a Zero Trust requirement in its own right. In addition to restricting access, a Zero Trust architecture uses telemetry to detect anomalies, inform trust decisions, and refine policy. The capability set covers Log All Traffic, SIEM, Common Security and Risk Analytics, User and Entity Behavior Analytics, Threat Intelligence Integration, and Automated Dynamic Policies.

VCF Log Management collects logs from supported and configured platform, component, and audit sources. Parsers normalize available fields for search and correlation, while field coverage and event semantics vary by source. VCF Log Management supports centralized analysis, configurable retention for supported audit data, and forwarding to external SIEM platforms. Individual components expose documented logging and syslog options that administrators must enable and scope. The resulting records can contribute to a time-correlated infrastructure audit trail, but they do not provide full packet capture, guarantee every desired audit field in every event, or satisfy enterprise-wide Log All Traffic requirements by themselves.

VCF Operations contributes to common security and risk analytics through operational anomaly detection that uses dynamic and static thresholds to flag deviations from the observed behavior of monitored infrastructure and workloads. Organizations can forward that telemetry to external user and entity behavior analytics (UEBA) or SIEM platforms for broader correlation; VCF Operations is not an enterprise UEBA platform. VCF Operations for Networks collects metrics on distributed firewall rule counts, packet drops, and traffic patterns, and its flow analysis can identify communication paths that are not covered by the reviewed firewall policy.

vDefend adds network-specific visibility and analytics. Security Intelligence analyzes observed traffic flows and can recommend firewall rules, identify traffic not covered by policy, and flag rules that no longer match observed traffic. This analysis can support a policy-review cycle. The Security Segmentation Score summarizes selected flow and firewall-configuration factors; it is an assessment aid rather than proof that the intended security architecture is effective. Distributed IDS/IPS generates classified events when configured signatures match traffic. Advanced Threat Prevention adds behavioral and machine-learning analysis, and malicious-IP feeds can support blocking rules when they are enabled and kept current. Gateway Firewall TLS inspection can decrypt traffic selected by policy, inspect it, and re-encrypt it before forwarding. Clients must trust the inspection certificate authority, and organizations must account for certificate distribution, privacy, protocol compatibility, and traffic that is excluded from decryption. Broadcom describes the release-specific context in its vDefend 9.1 Zero Trust overview.

VCF provides infrastructure telemetry and log data that SIEM, UEBA, and threat-intelligence platforms can consume. Organizations pursuing a DoD-aligned Zero Trust architecture must also establish enterprise-wide source coverage, correlation, alerting, response processes, retention, and governance beyond the VCF and vDefend data sources.

Automation and Orchestration

DoD Automation and Orchestration pillar.

The DoD Automation and Orchestration pillar includes capabilities for a Policy Decision Point and policy orchestration, Critical Process Automation, Machine Learning, Artificial Intelligence, Security Orchestration, Automation, and Response (SOAR), API Standardization, and Security Operations Center and Incident Response functions. Target and advanced activities within those capabilities combine technology with enterprise policy, process, data, and operational integration.

The clearest contribution here is network-layer policy enforcement. vDefend functions as a network-layer policy enforcement point, evaluating traffic against centrally authored policy and enforcing the result at or near the workload interface, with context profiles, Gateway Firewall Layer 7 access profiles, and Identity Firewall providing the attribute dimensions that policy can reference. Security Intelligence applies machine learning to recommend policy, feeding the network policy lifecycle, while the broader Policy Decision Point and policy-engine functions remain part of the enterprise Zero Trust architecture.

VCF Operations can compare monitored configuration state with desired-state profiles and report drift within the scope of supported checks. Certificate-lifecycle workflows can automate supported renewal and replacement operations, but administrators remain responsible for prerequisites, change control, failure handling, and service-specific validation. Documented VCF APIs support infrastructure-as-code workflows, allowing organizations to version-control selected infrastructure and security configuration while applying role-based API authorization and transport protection.

For the security operations and incident response function, VCF Operations supports notification rules with detailed incident field mappings, and vDefend contributes detection, classification, and containment: Security Intelligence categorizes events by impact (Critical, High, Medium, Low) and by MITRE ATT&CK tactic, and NDR correlates events into campaigns for triage. Full incident response process governance and security orchestration, automation, and response across domains depend on a dedicated SOAR platform; the VCF stack provides the detection signals and the enforcement actions that such a platform orchestrates.

Mapping to the NIST SP 800-207 Tenets

The *Direct* and *Supporting* ratings apply only to infrastructure-layer capabilities supplied by core VCF and vDefend. They do not represent enterprise-wide Zero Trust maturity or compliance. Capabilities that require identity-provider policy, endpoint management, SIEM, UEBA, SOAR, data governance, application security tooling, or organizational process are rated *Supporting* even where the VCF stack provides enforcement points, telemetry, or automation hooks. No single product implements Zero Trust by itself.

The published Broadcom NIST SP 800-207 companion assesses its covered products against all seven tenets. The VCF and vDefend values reproduce the companion ratings with *Meets* translated to *Direct* and *Contributes* translated to *Supporting*. *Direct* means the product provides the described capability within its assessed scope. *Supporting* means that the product provides a relevant mechanism but the tenet also requires organizational process, broader scope, or another product. The source version is 910-20260623-01.

NIST SP 800-207 Tenet	VCF	vDefend
1. All data sources and computing services are resources	Supporting	Supporting
2. All communication is secured regardless of network location	Direct	Supporting
3. Access to individual resources is granted per-session	Direct	Supporting
4. Access is determined by dynamic policy	Direct	Direct
5. The enterprise monitors the integrity and posture of all assets	Direct	Direct
6. Authentication and authorization are dynamic and enforced before access	Direct	Supporting
7. The enterprise collects state data and uses it to improve posture	Direct	Supporting

Mapping to the NIST SP 800-207 Deployment Approaches

NIST SP 800-207 describes three deployment approaches. A VCF design can contribute mechanisms to each approach, depending on the deployed components and integrations.

Enhanced identity governance uses identity as the primary input to access decisions. VCF SSO federates with external identity providers through supported standard protocols, VCF-level roles provide centralized authorization, and the OAuth API client model supports non-human identities for automation.

Micro-segmentation places policy enforcement at a granular resource boundary. The vDefend distributed firewall can enforce rules at the virtual interfaces of supported and protected workloads, and dynamic security groups can associate policy with workload attributes rather than only network addresses.

Network infrastructure and software-defined perimeters decouple logical workload connectivity from physical topology. NSX overlay networking creates logical segments. Administrators define the management-plane network paths and ingress controls as part of the deployment architecture.

In the logical component model of NIST SP 800-207, this architecture positions the vDefend distributed firewall as a distributed policy enforcement point at supported protected-workload interfaces, with NSX Manager and the Security Services Platform performing network-policy administration functions. The enterprise policy engine and trust algorithm remain broader architectural functions. They can integrate with VCF through supported identity federation, APIs, and telemetry, subject to the interfaces and decision workflows implemented by the organization.

Designing a Zero Trust Architecture on VCF

A Zero Trust deployment on VCF assembles these capabilities in a particular order, because some of them supply the information the others need.

Identity design comes first. Connecting VCF SSO to an enterprise identity provider through a supported SAML or OIDC configuration can place federated interactive sign-ins under the provider's multifactor-authentication and conditional-access policies. Administrators must separately govern local, emergency, service-account, and API authentication paths. Role assignments scoped by function and inventory location build on that foundation. Automation accounts should use narrowly scoped, revocable credentials where the applicable API supports them rather than embedded user passwords.

Host-trust evidence begins at provisioning. Enabling Secure Boot and TPM 2.0 Measured Boot before a host enters service provides signed-boot validation and boot measurements that an attestation verifier can evaluate. Monitoring the reported attestation state through VCF Operations can identify reported failures. Desired images, configuration baselines, and lifecycle state provide separate evidence about the settings and software managed by those mechanisms.

Segmentation design starts with observation. VCF Operations for Networks and vDefend Security Intelligence map observed traffic flows so architects can review communication paths before authoring policy. Using reviewed flow data can reduce both over-permissive rules and rules that disrupt required application communication. The observation window should span the relevant business cycles so that periodic activity such as backups, batch processing, and month-end jobs appears in the data. Observed flows require review before they become rules: in an environment that may already be compromised, malicious traffic appears in flow data alongside legitimate communication. Enforcement can then proceed in stages across infrastructure services, environment boundaries, and application-level rules using Application ID and Layer 7 context. A default-deny model is a configured target state rather than an automatic result. Security Intelligence recommendations and the Security Segmentation Score provide inputs to ongoing human review as traffic and applications change.

Data protection decisions center on key custody. Keys held in an external KMS keep key control separate from the infrastructure that uses them, which supports organizations that must demonstrate customer control of encryption keys; the vSphere Native Key Provider serves deployments that do not require that separation. vSAN data-at-rest encryption and VM encryption draw keys from either provider, and vSAN data-in-transit encryption and Encrypted vMotion protect data moving between hosts.

Telemetry integration belongs in the initial deployment. Configuring VCF Log Management and supported component forwarding during platform deployment allows collection to begin at the point when each source is enabled. Administrators should verify source coverage, time synchronization, parsing, retention, forwarding, and alerting rather than assume that deployment alone creates a complete audit trail.

With identity, trust, segmentation, encryption, and telemetry in place, supported automation can help maintain selected controls. Organizations can compare monitored state with desired-state profiles, automate supported certificate operations, coordinate lifecycle workflows, and manage selected policy through documented APIs. These functions contribute to activities that CISA associates with more mature operation, but an organization's maturity also depends on enterprise-wide coverage, policy, process, measurement, and cross-domain integration.

Mapping to the CISA Zero Trust Maturity Model

The CISA Zero Trust Maturity Model, version 2.0, organizes Zero Trust into five pillars (Identity, Devices, Networks, Applications and Workloads, and Data) and three cross-cutting capabilities (Visibility and Analytics, Automation and Orchestration, and Governance). CISA defines Traditional, Initial, Advanced, and Optimal characteristics for individual functions and for the cross-cutting capabilities. Those stages describe an organization's enterprise-wide implementation rather than a product. Product mechanisms can contribute to a function, but product-level contributions do not establish an organizational maturity stage.

CISA Pillar or Capability	Technical contributions	Limits and external dependencies
Identity	VCF SSO federation for supported interactive authentication; VCF and component RBAC; scoped API credentials	Enterprise identity governance, phishing-resistant multifactor authentication, risk-based access, lifecycle governance, access recertification, and coverage of non-federated paths depend on identity-provider and organizational controls
Devices	ESX inventory, Secure Boot, TPM attestation state, lifecycle management, and configuration monitoring for supported components	User endpoints, mobile devices, enterprise-wide device inventory, EDR/XDR, device-risk decisions, and automatic isolation require external platforms and policy integration
Networks	NSX logical networking; vDefend micro-segmentation, Application ID, Layer 7 policy, and selected TLS inspection; encryption for supported vSAN and vMotion traffic	Physical and external networks, enterprise-wide policy decisions, unsupported protocols, excluded encrypted traffic, and non-VCF resources require additional controls
Applications and Workloads	VM and VKS-node isolation, workload inventory, vDefend network enforcement, IDS/IPS, Advanced Threat Prevention, and NDR	Secure development, software supply-chain controls, application authentication, application security testing, container-runtime controls, and complete application inventory require other tools and processes
Data	vSAN and VM encryption, supported key-provider integration, and infrastructure RBAC	Enterprise data inventory, cataloging, categorization, labeling, rights management, content-aware data loss prevention, and data-governance policy remain external
Visibility and Analytics	VCF Log Management, VCF Operations, Security Intelligence, IDS/IPS, and NDR provide infrastructure and network-security telemetry	Enterprise-wide collection, source normalization, cross-domain correlation, UEBA, alert governance, and response measurement require SIEM, analytics, and operational processes
Automation and Orchestration	Network-policy automation, lifecycle workflows, supported certificate operations, and authenticated APIs	Enterprise-wide orchestration, contextual response across domains, decision governance, and SOAR require external platforms and processes
Governance	VCF and vDefend can provide enforcement mechanisms, configuration evidence, and audit data	Governance ownership, policy approval, risk acceptance, metrics, legal and regulatory interpretation, and enterprise oversight are organizational responsibilities

Security Intelligence recommendations can inform segmentation-policy changes from observed traffic, but administrators must review the observations, policy intent, and proposed rules. Data inventory and categorization, secure application development, security testing, governance, and enterprise-wide automated response depend on organizational processes and tools beyond the platform.

Mitigating Zero Trust Architecture Threats from SP 800-207

NIST SP 800-207 identifies several threats to Zero Trust implementations. VCF and vDefend can contribute mechanisms relevant to some of those threats within their documented scope. The surrounding enterprise architecture remains responsible for the complete mitigation.

Subversion of the policy decision process. Monitoring supported management components and logging configuration changes can help administrators detect or investigate changes to policy infrastructure. Effectiveness depends on source coverage, separation of duties, protection of the logging path, alerting, and review. These controls do not substitute for hardening and resilient design of the policy engine and policy administrator.

Denial of service or network disruption. Supported high-availability designs can reduce dependence on a single component, but architects must identify and test the availability of each policy engine, policy administrator, and policy enforcement point.

Stolen credentials and insider threat. Configurable token lifetimes, narrowly scoped roles, separation of duties, monitoring, and multifactor authentication for supported federated sign-ins can reduce the access available to a compromised identity. A valid compromised credential can still exercise its assigned permissions.

Visibility on the network. VCF Operations for Networks collects traffic metadata and flow analysis without requiring payload decryption, and vDefend's micro-segmentation flow analysis surfaces communication patterns for policy refinement.

Storage of system and network information. Role-based access, protected administrative paths, retention controls, and monitoring of access to security telemetry can reduce exposure. A separate audit partition changes retention and operational separation but does not by itself control every path to the stored data.

Reliance on proprietary data formats. The identity layer supports standard federation protocols such as OIDC and SAML, while syslog and documented APIs provide integration paths. These interfaces reduce some integration dependencies but do not make policy models, event schemas, or configurations portable between products.

Use of non-person entities in Zero Trust architecture administration. Narrowly scoped service-account permissions, rotation, monitoring, and configurable token lifetimes can limit the exposure associated with compromised automation credentials. Organizations must also validate automated decisions, tune false-positive and false-negative handling, and control which actions an automated agent can invoke.

Capability Contribution Matrices

The DoD Zero Trust Capability Execution Roadmap comparison is an editorial, capability-level analysis of documented product mechanisms. It is not a published SCF crosswalk, activity-level assessment, or compliance attestation. *Direct* and *Supporting* describe the relationship between a product mechanism and the capability at the infrastructure or network-security layer; a *Supporting* entry does not mean that the complete DoD capability is covered. Aggregate coverage percentages require an activity-level assessment with deployment evidence. The Roadmap numbers capabilities by pillar as 1 User, 2 Device, 3 Application and Workload, 4 Data, 5 Network and Environment, 6 Automation and Orchestration, and 7 Visibility and Analytics.

VMware Cloud Foundation

Direct: the product performs the function described. *Supporting*: the product supplies a mechanism that an organization combines with its own process or with complementary products.

DoD Zero Trust Capability	VCF Feature	Contribution
1.1 User Inventory	VCF SSO identity store and component account management	Supporting
1.2 Conditional User Access	RBAC across vCenter, NSX, VCF Operations, VCF Automation, and VKS; contextual, device, and session conditions depend on the identity provider and supported federated sign-in path	Supporting
1.3 Multi-Factor Authentication	Applied by the identity provider to supported federated sign-ins; local, emergency, service-account, and API paths require separate controls	Supporting
1.4 Privileged Access Management	RBAC privilege scoping; participates in just-in-time and time-limited workflows via enterprise PAM integration	Supporting
1.5 Identity Federation and Credentialing	VCF SSO federation through supported SAML or OIDC authentication; separate JIT, SCIM, or AD/LDAP provisioning paths where supported	Direct
1.6 Behavioral, Contextual ID, and Biometrics	VCF Operations infrastructure anomaly telemetry can be forwarded to enterprise UEBA platforms; behavioral identity and biometrics remain external	Supporting
1.7 Least Privileged Access	Granular RBAC scoped by function and inventory location	Direct
1.8 Continuous Authentication	Federation, token lifetimes, and session controls provide integration points; continuous authentication depends on identity-provider, PAM, conditional-access, and session-risk tooling	Supporting
1.9 Integrated ICAM Platform	VMCA, certificate lifecycle management, and federation support integration with enterprise ICAM	Supporting
2.1 Device Inventory	vCenter inventory of managed objects and VCF Operations configuration-item records for monitored infrastructure	Direct
2.2 Device Detection and Compliance	VCF Operations inventory and discovery, boot-attestation state, and supported configuration-assessment evidence	Supporting
2.3 Device Authorization with Real-Time Inspection	Secure Boot and TPM Measured Boot provide boot-attestation evidence; an additional policy integration must use that evidence in live authorization decisions	Supporting
2.5 Asset, Vulnerability and Patch Management	VCF lifecycle management, including vSphere Lifecycle Manager functions, supported patch workflows, and configuration drift detection; enterprise vulnerability discovery and prioritization remain external	Supporting

DoD Zero Trust Capability	VCF Feature	Contribution
2.7 Endpoint and Extended Detection and Response	Host integrity controls, log analysis, and forwarding to EDR/XDR/SIEM; partner integration	Supporting
3.1 Application Inventory	vCenter and VCF Operations inventory of workloads	Supporting
3.3 Software Risk Management	Software artifact integrity and controlled distribution (content library policies, signing); application software risk management remains a toolchain function	Supporting
3.4 Resource Authorization and Integration	Real-time authorization enforcement; vSphere VM isolation; Supervisor namespace RBAC	Direct
3.5 Continuous Monitoring and Ongoing Authorizations	VCF Operations and VCF Log Management provide monitoring evidence; an external policy process or engine must use that evidence in ongoing authorization decisions	Supporting
4.1 Data Catalog Risk Alignment	VCF Operations for Networks flow analysis; infrastructure asset mapping	Supporting
4.3 Data Labeling and Tagging	vSphere Tag Service and storage/compute policy metadata for classification programs to reference	Supporting
4.5 Data Encryption and Rights Management	vSAN data-at-rest encryption, VM encryption, FIPS-validated modules where configured within the validation boundary, and an external KMS or Native Key Provider	Supporting
4.7 Data Access Control	vSAN software-defined storage; layered RBAC, encryption privilege, and secrets management	Direct
5.1 Data Flow Mapping	VCF Operations for Networks end-to-end network map and flow analysis	Supporting
5.2 Software Defined Networking	NSX logical networking: overlays, routing, and transport zones; network asset discovery	Direct
5.3 Macro Segmentation	Network partitioning through VLANs, vSphere Distributed Switches, and NSX overlay segments and routing domains	Direct
5.4 Micro Segmentation	NSX logical-networking foundation and VCF Operations for Networks planning and flow analysis (segmentation enforcement performed by vDefend)	Supporting
6.1 Policy Decision Point and Orchestration	Real-time authorization enforcement within each management domain	Supporting
6.6 API Standardization	Authenticated, authorized, and encrypted APIs across components, including VKS	Supporting
6.7 Security Operations Center and Incident Response	VCF Operations notification rules and incident field mapping	Supporting
7.1 Log All Traffic	Centralized platform audit and event logging with a time-correlated audit trail and syslog forwarding; network traffic logging depends on NSX and vDefend policy	Supporting
7.2 Security Information and Event Management	Log management and analytics; near-real-time analysis, correlation, and forwarding to the enterprise SIEM	Supporting
7.3 Common Security and Risk Analytics	VCF Operations cross-stack monitoring and analytics	Supporting
7.4 User and Entity Behavior Analytics	Infrastructure anomaly telemetry that can be forwarded to enterprise UEBA and SIEM platforms	Supporting

Secure Boot, TPM attestation, and lifecycle patching are core VCF mechanisms. vDefend contributes network-layer mechanisms relevant to 4.4 Data Monitoring and Sensing, 4.6 Data Loss Prevention, and 7.5 Threat Intelligence Integration. Capabilities without a mapped product mechanism remain organizational, toolchain, user-endpoint, or enterprise-control functions. These include 2.4 Remote Access, 2.6 Unified Endpoint Management and Mobile Device Management (UEM/MDM), 3.2 Secure Software Development, 4.2 DoD Enterprise Data Governance, 6.2 Critical Process Automation, 6.3 Machine Learning, 6.4 Artificial Intelligence, 6.5 Security Orchestration, Automation, and Response, and 7.6 Automated Dynamic Policies.

VMware vDefend

Direct: the product performs the function described. *Supporting*: the product supplies a mechanism that an organization combines with its own process or with complementary products.

DoD Zero Trust Capability	vDefend Feature	Contribution
1.2 Conditional User Access	Identity Firewall: Active Directory user/group-aware network policy	Supporting
1.4 Privileged Access Management	Role-based access control over its own management plane (Security Services Platform) with differentiated built-in roles; not a privileged access management product	Supporting
2.1 Device Inventory	Security Services Platform workload inventory; NDR sensor mutual TLS onboarding	Supporting
2.3 Device Authorization with Real-Time Inspection	Security Intelligence, IDS/IPS, and NDR provide network observations that an external policy system can consider; vDefend does not perform enterprise device authorization	Supporting
2.7 Endpoint and Extended Detection and Response	Network Detection and Response with MITRE ATT&CK mapping; network-layer detection and response complementing endpoint EDR	Supporting
3.4 Resource Authorization and Integration	Distributed firewall as network-layer policy enforcement point with local policy evaluation; dynamic, attribute-based groups	Direct
4.4 Data Monitoring and Sensing	Restricts and observes workload communication paths through tag-based firewall policy; does not inspect or classify data content	Supporting
4.6 Data Loss Prevention	Distributed firewall restriction of exfiltration paths at the network layer; content inspection and classification remain external	Supporting
5.1 Data Flow Mapping	Security Intelligence live traffic flow visualization and security posture mapping	Direct
5.2 Software Defined Networking	Security enforcement within the software-defined network (SDN) that NSX provides; distributed firewall at the virtual network interface (vNIC)	Supporting
5.3 Macro Segmentation	Perimeter and zone segmentation through the distributed and gateway firewalls	Direct
5.4 Micro Segmentation	Distributed firewall at supported protected-workload vNICs; configurable Layer 2 through Layer 7 policy and a staged default-deny design	Direct
6.1 Policy Decision Point and Orchestration	Policy enforcement at or near the workload interface using context profiles, Gateway Firewall Layer 7 access profiles, and Identity Firewall, plus machine-learning-assisted policy recommendations; central decision functions remain part of the enterprise architecture	Supporting

DoD Zero Trust Capability	vDefend Feature	Contribution
6.7 Security Operations Center and Incident Response	Security Intelligence impact and MITRE classification; NDR campaign timelines; containment actions through firewall policy and integrations	Supporting
7.1 Log All Traffic	Firewall and security-event logging, enabled and scoped per policy rule	Supporting
7.2 Security Information and Event Management	Structured event data and dashboards; forwarding to the enterprise SIEM	Supporting
7.3 Common Security and Risk Analytics	Security Intelligence continuous flow analysis and trend reporting	Supporting
7.5 Threat Intelligence Integration	Advanced Threat Prevention, malicious-IP feeds, and continuously updated IDS/IPS signatures	Supporting

Conclusion

VCF and vDefend contribute infrastructure-level mechanisms relevant to NIST SP 800-207 and the DoD Zero Trust Reference Architecture. The strongest direct contribution is in the Network and Environment pillar, where NSX supplies software-defined networking and vDefend places distributed firewall enforcement at supported virtual-workload interfaces. Identity federation and role management contribute to the User pillar. Host attestation, inventory, configuration monitoring, and lifecycle workflows contribute to the Device pillar. Hypervisor isolation contributes to Application and Workload controls. Encryption and key-provider integration contribute to Data protection. The resulting architecture still depends on correct configuration, enterprise policy, and external identity, endpoint, analytics, governance, application-security, and response systems.

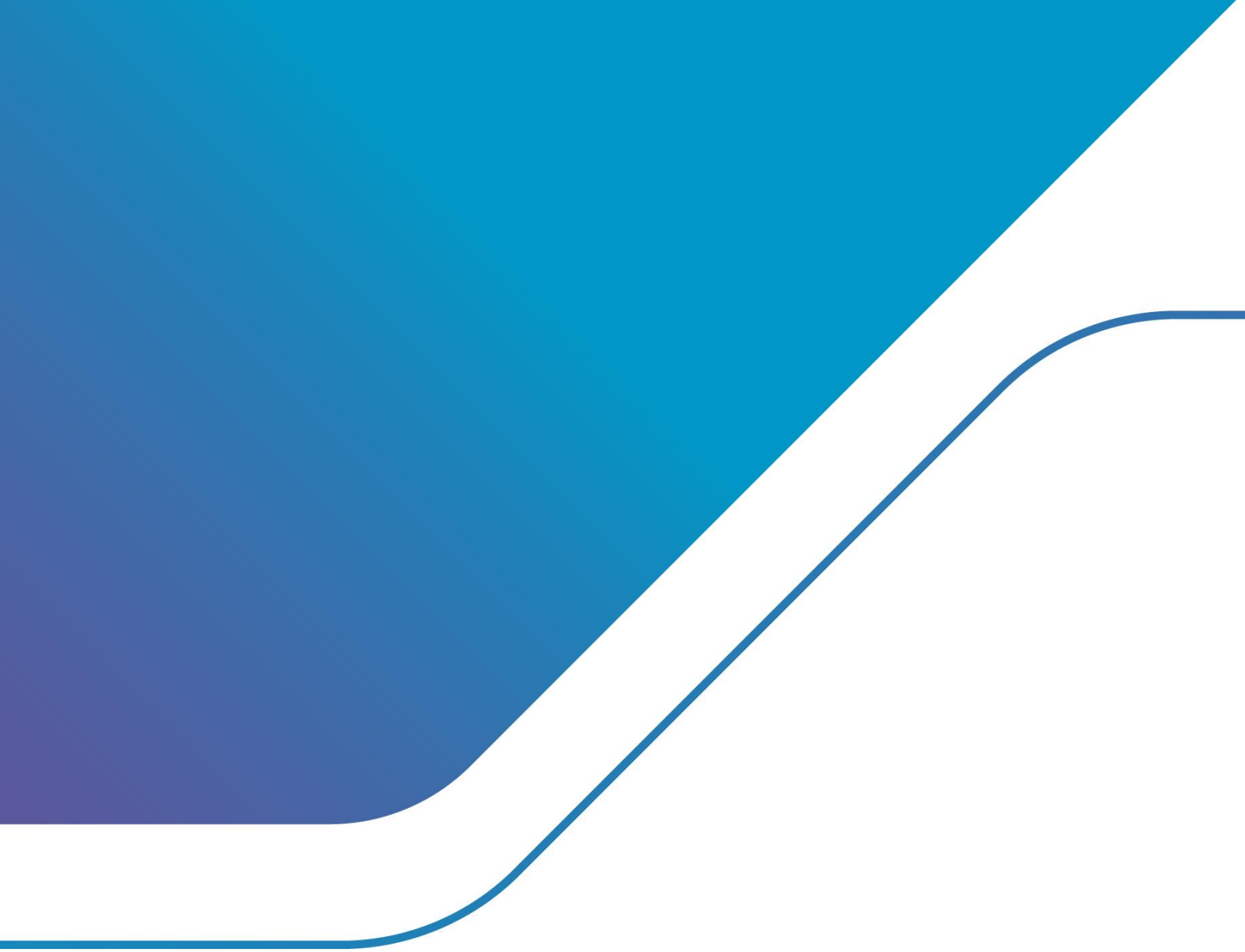
Zero Trust is an architectural strategy that spans technology, process, and organizational responsibility, and no single product implements it alone. Core VCF supplies infrastructure mechanisms, and vDefend supplies network-security enforcement and detection. Organizations combine those mechanisms with enterprise identity, endpoint security, SIEM and analytics, data governance, application security, privileged-access, recovery, and incident-response controls.

Appendix: Enterprise Components That Complete Each Pillar

DoD Pillar	Enterprise components
User	Enterprise identity provider for multifactor authentication, conditional access, and session-risk decisions; PAM tooling for just-in-time privilege; ICAM governance for credential issuance and access recertification
Device	UEM/MDM for user endpoints; EDR/XDR platforms consuming host telemetry; enterprise CMDB and asset-management process
Network and Environment	Physical-network controls outside the virtual infrastructure; enterprise policy engine for cross-domain access decisions
Application and Workload	Secure software development toolchain; application security testing; software supply-chain risk management
Data	Data governance program covering classification, cataloging, and labeling policy; content-aware data loss prevention
Visibility and Analytics	SIEM for enterprise-wide correlation; UEBA; threat-intelligence platforms that consume and enrich the stack's detections
Automation and Orchestration	SOAR platform for cross-domain response; enterprise Policy Decision Point; incident response process governance

Additional Resources

- NIST Special Publication 800-207, *Zero Trust Architecture*
- DoD Zero Trust Reference Architecture, Version 2.0
- DoD Zero Trust Strategy
- DoD Zero Trust Capability Execution Roadmap, Version 1.1
- CISA Zero Trust Maturity Model, Version 2.0
- Secure Controls Framework, version 2026.1.1, and license terms
- Broadcom NIST SP 800-207 Companion Guide for VCF 9.1
- VCF Security Configuration Guide 9.1
- Broadcom Technical Documentation for VMware Cloud Foundation 9.1
- *Authentication and Authorization Best Practices for VCF 9*
- *Rapid Non-Disruptive Security Patching in VMware Cloud Foundation 9.1*
- VCF encryption guidance
- VMware Cloud Foundation Security and Compliance Guidance



vmware® by Broadcom

Copyright © 2026 Broadcom. All rights reserved.
The term "Broadcom" refers to Broadcom Inc. and/or its subsidiaries. For more information, go to www.broadcom.com. All trademarks, trade names, service marks, and logos referenced herein belong to their respective companies. Broadcom reserves the right to make changes without further notice to any products or data herein to improve reliability, function, or design. Information furnished by Broadcom is believed to be accurate and reliable. However, Broadcom does not assume any liability arising out of the application or use of this information, nor the application or use of any product or circuit described herein, neither does it convey any license under its patent rights nor the rights of others.